



# Vulnerability Assessment Report

## Target Website

<https://www.gogoair.com>

Read-Only Web Security Assessment

**Prepared by**

**Abrar**

**July 2026**

---

---

# Executive Summary

A read-only vulnerability assessment was performed on the public website [www.gogoair.com](http://www.gogoair.com) to evaluate its external security posture. The assessment focused on passive reconnaissance, HTTP response analysis, security header inspection, technology identification, and publicly accessible web resources. No exploitation or intrusive testing was performed during the assessment. The review identified several informational observations and confirmed the presence of multiple recommended security controls.

---

---

# Scope

| Item            | Description                                                   |
|-----------------|---------------------------------------------------------------|
| Target          | <a href="https://www.gogoair.com">https://www.gogoair.com</a> |
| Assessment Type | Read-Only                                                     |
| Testing Method  | Manual Security Assessment                                    |
| Tools           | Burp Suite Community Edition<br>Google Chrome DevTools        |

## Out of Scope

- Authentication bypass
  - Denial of Service
  - Brute Force
  - Exploitation
  - Privilege Escalation
-

---

# Methodology

| Phase                      | Description                                                           |
|----------------------------|-----------------------------------------------------------------------|
| Reconnaissance             | Explored publicly accessible resources and application structure.     |
| Technology Identification  | Identified technologies through HTTP responses and page analysis.     |
| Security Header Review     | Reviewed HTTP security headers for common security protections.       |
| API Discovery              | Identified publicly accessible API endpoints through manual analysis. |
| Search Function Assessment | Tested user input handling using non-destructive payloads.            |

## Assessment Approach

The assessment was performed using manual, read-only techniques. No exploitation, brute-force attacks, denial-of-service activities, or authentication bypass attempts were performed during testing.

---

---

# Technologies Identified

| Technology        | Evidence                 |
|-------------------|--------------------------|
| Microsoft IIS 10  | HTTP Response Header     |
| ASP.NET Core      | Response Headers         |
| Kentico Xperience | HTML Source / JavaScript |

The technologies were identified through manual inspection of HTTP response headers and publicly accessible application resources.

---

# Finding 1

## HTTP Security Headers

### Description

The HTTP response headers were manually reviewed to evaluate the implementation of common browser security controls.

### Evidence

| Response |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         | Insp |
|----------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------|
| ln       | PrettyRawHexRender                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      | Requ |
|          | 1 HTTP/2 200 OK                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         | Requ |
|          | 2 Date: Mon, 20 Jul 2026 22:39:21 GMT                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   | Requ |
|          | 3 Content-Type: text/html; charset=utf-8                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                | Requ |
|          | 4 Server: Microsoft-IIS/10.0                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            | Resp |
|          | 5 Access-Control-Allow-Credentials: false                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               |      |
|          | 6 Access-Control-Allow-Origin: *                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |      |
|          | 7 Cache-Control: no-cache, no-store                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |      |
|          | 8 Pragma: no-cache                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |      |
|          | 9 Set-Cookie: .AspNetCore.Antiforgery.cdV5uW_Ejgc=CfDJ8G0AEFy7JfxBvYAXQ2TVxdrd_CXM4HoyGk1VJ60av09-CB-M4ChH4aUuN2hZNGa489oQEj0Z7-fiqiLzFibm27sxu2QeNs3rdB3hCv57poNam5A02b0ggr9tMqH4e3D-WB3rP1ln5xgyxModNPYAfu4; path=/; samesite=strict; httponly                                                                                                                                                                                                                                                                                                        |      |
|          | 10 Vary: Accept-Encoding                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |      |
|          | 11 Strict-Transport-Security: max-age=31536000; includeSubDomains                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |      |
|          | 12 X-Frame-Options: SAMEORIGIN                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                          |      |
|          | 13 Content-Security-Policy: default-src 'self'; script-src 'self' 'unsafe-inline' 'unsafe-eval' https://cdn.cookieclaw.org https://www.googletagmanager.com https://*.vidyard.com https://learn.business.gogoair.com https://*.google.com https://*.googleapis.com https://*.gstatic.com https://cdnjs.cloudflare.com https://code.jquery.com https://cdn3.devexpress.com https://assets.adobedtm.com https://static.hotjar.com https://script.hotjar.com https://munchkin.marketo.net https://connect.facebook.net https://googleads.g.doubleclick.net |      |

## Observation

- Strict-Transport-Security (HSTS)
- Content-Security-Policy (CSP)
- X-Frame-Options
- Access-Control-Allow-Origin
- HttpOnly Cookie Attribute

## Risk Level

LOW

## Recommendation

Continue maintaining these security controls and review them periodically to ensure they remain aligned with current security best practices.

---

---

# Finding 2

## Server Banner Disclosure

### Description

The HTTP response header disclosed the web server software and version: Microsoft-IIS/10.0

### Why Does It Matter?

Revealing server software information may assist attackers during the reconnaissance phase by identifying the web server technology and its version. This information can be used to search for publicly known vulnerabilities affecting that software.

### Evidence

```
2 Date: Mon, 20 Jul 2026 22:39:21 GMT
3 Content-Type: text/html; charset=utf-8
4 Server: Microsoft-IIS/10.0
```

### Risk Level

LOW

### Recommendation

Consider minimizing unnecessary server information disclosure where operationally appropriate. If possible, configure the web server to suppress or generalize the Server response header.

---



---

# Finding 3

## Public API Endpoint Discovery

### Description

During manual reconnaissance, a publicly accessible API endpoint was identified: GET /webapi/stcsapi/products

The endpoint returned product information in JSON format without requiring authentication.

### Evidence



```

https://gogoair.co.emerald.net https://*.adobebeac.net https://*.no
https://*.hotjar.io wss://*.hotjar.com; frame-src 'self' https://
  https://www.facebook.com https://play.vidyard.com
https://learn.business.gogoair.com; frame-ancestors 'self'
https://www.google.com; object-src 'none'; base-uri 'self';
10 Permissions-Policy: geolocation=(self)
11 Referrer-Policy: strict-origin-when-cross-origin
12 X-Content-Type-Options: nosniff
13 X-Xss-Protection: 1; mode=block
14
15 [
    {
        "name": "Gogo Galileo - FDX"
    },
    {
        "name": "Gogo Galileo - HDX"
    },
    {
        "name": "L5 + X3"
    },
    {
        "name": "LX5"
    },
    {
        "name": "Plane Simple Ka"
    },
    {
        "name": "Plane Simple Ku"
    }
]
1

```

## Observation

The endpoint returned publicly available product names only. No authentication bypass, sensitive information disclosure, or unauthorized access was observed during testing.

## Risk Level

Informational

## Recommendation

Review publicly accessible API endpoints periodically and verify that only intended public information is exposed.

---

---

# Risk Summary

| Finding                       | Risk Level    | Status                       |
|-------------------------------|---------------|------------------------------|
| HTTP Security Headers         | Low           | Security controls identified |
| Server Banner Disclosure      | Low           | Information disclosure       |
| Public API Endpoint Discovery | Informational | Public data only             |

---

---

# Recommendations

- Continue maintaining HTTP security headers.
  - Periodically review publicly accessible API endpoints.
  - Minimize unnecessary server information disclosure where operationally appropriate.
  - Perform regular security assessments to identify newly introduced risks.
  - Continue secure input validation and output encoding practices.
-

---

# Conclusion

The assessment was conducted using a read-only methodology and focused on publicly accessible components of the target website. Manual testing identified several informational observations, including exposed technology details and publicly accessible API endpoints, while also confirming the presence of important security mechanisms such as HTTP security headers.

No Critical or High-risk vulnerabilities were identified within the scope of this assessment. However, regular security reviews, continuous monitoring, and secure development practices are recommended to maintain and further improve the application's security posture.

End of Report

---